

Mini Compliance Program — NIST 800-53 (Riverside Physical Therapy)

A self-directed GRC project simulating the foundational work a Governance, Risk, and Compliance (GRC) analyst performs when building a compliance program for a healthcare organization from the ground up.

Project Summary

This project builds a mini compliance program for **Riverside Physical Therapy**, a fictional single-location outpatient clinic with approximately 20–30 staff. Using **NIST SP 800-53** as the governing framework (selected for its strong alignment with HIPAA in U.S. healthcare settings), the project walks through the full lifecycle a real compliance program follows:

1. **Scoping** — defining the organization, its systems, and what's in/out of bounds for assessment
2. **Control selection** — tailoring 18 controls across 7 relevant NIST families (Access Control, Audit & Accountability, Incident Response, Identification & Authentication, System & Communications Protection, Contingency Planning, and Configuration Management)
3. **Control matrix** — assessing each control's current status (Missing / Partial / Implemented), assigning an accountable owner, and documenting specific remediation actions
4. **Gap analysis** — prioritizing the most significant gaps using a likelihood/impact lens, and proposing a sequenced, realistic remediation roadmap

Deliverables

File	Description
Riverside_Compliance_Program_Overview.pdf	Program scope, goals, maturity assessment, and full gap analysis with 5 prioritized findings
Riverside_Control_Matrix.xlsx / .pdf	18-control matrix with status, ownership, and remediation actions, plus a live summary tab

What I Did

- Selected and justified a compliance framework (NIST 800-53) based on the organization's regulatory environment rather than picking one arbitrarily
- Scoped a realistic environment (EHR, workstations, network/VPN, email, backups, access management) the way an analyst would before any assessment begins
- Tailored a representative 18-control sample from NIST's full catalog, rather than assessing every control indiscriminately
- Assessed each control's real-world status and assigned ownership to roles that realistically exist at a small organization (IT Support Specialist, Office Manager, Clinic Director)

- Performed a likelihood/impact-based gap analysis to prioritize 5 findings out of many possible gaps
- Built a sequenced remediation roadmap that accounts for dependencies (e.g., policy work before technical fixes, technical fixes before structural/programmatic changes)
- Identified a cross-cutting structural finding — concentration of control ownership in a single role — that wasn't tied to any one control, but emerged from looking at the matrix as a whole

What I Learned

- **Frameworks are translation tools, not checklists.** A control like “the organization manages information system accounts” means nothing until it's mapped to a specific system, a specific owner, and a specific current state. Most of the real work in GRC is that translation step.
- **Status isn't binary.** Almost nothing is fully “done” or fully “missing” — most controls in a real organization sit in a partial state, and learning to assess *degree* of implementation (not just presence/absence) is a core analytical skill.
- **Ownership without accountability isn't ownership.** Assigning every gap to “IT” without naming a specific role creates the same failure mode auditors flag constantly: a control nobody is actually responsible for never gets fixed.
- **Prioritization is a skill, not a formality.** With 7 missing controls to choose from, picking the right 4–5 to highlight — and being able to explain *why* those and not others — was harder and more valuable than identifying the gaps in the first place.
- **The most useful findings aren't always in the matrix.** The biggest single insight from this project (ownership concentration) wasn't a control gap at all — it came from stepping back and asking a structural question about the matrix itself, rather than just reading down the rows.

Real-World Application

This mirrors work that real GRC analysts perform constantly, particularly at small and mid-sized healthcare organizations that don't have a dedicated compliance department:

- **Pre-audit readiness** — control matrices like this one are exactly what organizations build before a HIPAA risk assessment, SOC 2 audit, or payer/insurance compliance review
- **Vendor and partner due diligence** — healthcare organizations are increasingly asked by insurers, partners, and regulators to demonstrate documented control ownership, not just technical safeguards
- **Incident and breach preparedness** — the HIPAA Breach Notification Rule findings in this project reflect a real, recurring gap at smaller healthcare providers, where IT teams handle technical security but no one owns the legal/regulatory response process
- **Resource-constrained environments** — most small organizations don't have a CISO or compliance officer; this project intentionally reflects that reality by assigning controls to roles (IT Support, Office Manager, Clinic Director) that actually exist in organizations this size, rather than assuming idealized GRC staffing

Conclusion

This project demonstrates the foundational GRC analyst skill set: taking an abstract framework, applying it to a specific organization, identifying where reality falls short of the requirement, and building a realistic, prioritized plan to close that gap. It also reflects something important about real compliance work — the goal isn't a perfect scorecard, it's a defensible, well-reasoned path from where an organization stands today to where it needs to be, sequenced in a way that a small team can actually execute. The combination of technical assessment (the control matrix) and business communication (the program overview and gap analysis) reflects the dual nature of GRC work: it sits between IT/security execution and organizational risk decision-making, translating between the two.

This is a self-directed portfolio project using a fictional organization. It does not reflect any real company's compliance posture.

Mini Compliance Program

NIST 800-53 Compliance Assessment — Riverside Physical Therapy

Prepared by Kevin Liao

1. Compliance Program Overview

Organization & Scope

Organization: Riverside Physical Therapy (fictional outpatient clinic, built for portfolio purposes)

Scope: Single location, approximately 20–30 staff (clinicians, front desk, billing, administrative)

Framework: NIST SP 800-53, with alignment to the HIPAA Security Rule

Systems & Assets in Scope

- EHR / patient records system (primary repository of Protected Health Information)
- Staff workstations (Windows/macOS)
- Network infrastructure (router, Wi-Fi, VPN for remote access)
- Email and communication systems
- Backup and storage systems for patient records
- User account and access management

Program Goals

- Establish a baseline understanding of Riverside's current security and compliance posture
- Identify gaps against NIST 800-53 control families relevant to a small healthcare provider
- Produce a remediation roadmap suitable for presentation to clinic leadership
- Demonstrate alignment between technical controls and HIPAA Security Rule requirements

Current Maturity

Riverside's overall maturity is assessed as Initial / Ad Hoc. Several controls exist informally — access is managed but not formally documented, and basic technical safeguards (backups, role-based EHR permissions) are in place, largely as vendor defaults rather than the result of a deliberate, governed program. No dedicated compliance function exists; control ownership currently sits almost entirely with the IT Support function.

2. Control Matrix Summary

A full 18-control matrix was assessed across seven NIST 800-53 control families: Access Control (AC), Audit & Accountability (AU), Incident Response (IR), Identification & Authentication (IA), System & Communications Protection (SC), Contingency Planning (CP), and Configuration Management (CM). The complete matrix, including control-by-control status, ownership, and remediation actions, is provided as a companion spreadsheet (Riverside_Control_Matrix.xlsx).

Posture at a Glance

Status	Count
Missing	7 of 18 controls
Partial	8 of 18 controls
Implemented	3 of 18 controls

A notable cross-cutting observation: 14 of the 18 assessed controls are owned by a single role (IT Support Specialist), with only 2 owned by the Clinic Director and 1 by the Office Manager. While structurally typical for an organization of this size, this concentration of ownership represents a continuity and separation-of-duties risk in its own right, and is addressed as a standalone finding below.

3. Gap Analysis & Remediation Roadmap

The following five findings were prioritized from the full control matrix using a likelihood/impact framework. Items with severe regulatory or operational consequences were prioritized over items that, while still real gaps, carry lower standalone risk.

Finding 1 — No HIPAA Breach Notification Process (IR-6)

Likelihood / Impact: Low / Severe

Riverside has no defined process for notifying HHS or affected patients in the event of a PHI breach. HIPAA's Breach Notification Rule imposes strict reporting timelines; failure to meet them carries direct legal and financial exposure regardless of the breach's technical severity.

Remediation: Document breach notification timelines and designate a responsible party within the Incident Response Policy.

Owner / Timeline: Clinic Director / 0–30 days

Finding 2 — No Documented Incident Response Policy (IR-1)

Likelihood / Impact: Medium / High

No written incident response plan exists, meaning any real incident would be handled improvised rather than according to a defined process. This finding is foundational: addressing it strengthens both incident handling (IR-4) and breach reporting (IR-6).

Remediation: Draft and formally approve a written incident response policy covering roles, escalation contacts, and response steps.

Owner / Timeline: Clinic Director (approval), IT Support Specialist (drafting) / 0–30 days

Finding 3 — Backups Never Tested for Restoration (CP-10)

Likelihood / Impact: Medium / High

Backups run automatically but have never been validated through an actual restoration test. An unproven backup creates risk that a real outage or ransomware event reveals recovery does not work as assumed, directly threatening patient care continuity.

Remediation: Conduct a test restoration of backup data and establish this as a recurring annual task.

Owner / Timeline: IT Support Specialist / 30–60 days

Finding 4 — PHI Not Consistently Encrypted in Transit (SC-8)

Likelihood / Impact: Medium / High

Email is not consistently encrypted in cases where PHI may be discussed. Unencrypted transmission of PHI is a frequently cited pattern in real-world HIPAA enforcement actions, making this a realistic and material exposure.

Remediation: Adopt an encrypted email solution or secure patient communication portal, with staff training on appropriate use.

Owner / Timeline: IT Support Specialist / 30–60 days

Finding 5 — Control Ownership Concentrated in a Single Role

Likelihood / Impact: High / Medium

Fourteen of eighteen assessed controls are owned by the IT Support Specialist role, with no dedicated compliance function providing oversight or separation of duties. This is a structural, programmatic gap rather than a technical one: if this individual is unavailable, compliance-critical tasks have no backup owner, and no second party independently verifies that controls remain effective.

Remediation: Formally designate a part-time compliance coordination responsibility, distributed across existing staff, to review control status on a quarterly basis.

Owner / Timeline: Clinic Director / 60–90 days

Sequencing Rationale

Remediation is sequenced deliberately: policy-level fixes (Findings 1 and 2) come first because they are low-cost and because several other controls depend on them. Technical remediations (Findings 3 and 4) follow once response processes are in place to handle situations where those technical controls fail. The structural fix (Finding 5) comes last, once concrete remediation work exists for a compliance function to actually oversee.

Riverside Physical Therapy — NIST 800-53 Control Matrix

Mini Compliance Program | Framework: NIST SP 800-53 (HIPAA-aligned) | Prepared by Kevin Liao

Control ID	Family	Requirement	Current Status	Owner	Needed Actions / Remediation	Notes
AC-2	Access Control	Account Management: Accounts are created/disabled informally by IT support; no documented review cycle.	Partial	IT Support Specialist	Establish a quarterly access review and a documented offboarding checklist for departing staff.	
AC-3	Access Control	Access Enforcement: EHR has role-based permissions out of the box, actively used.	Implemented	IT Support Specialist	Maintain current role-based permissions; periodically verify roles still match job duties as staff change positions.	
AC-17	Access Control	Remote Access: VPN exists but no formal remote access policy or usage monitoring.	Partial	IT Support Specialist	Draft a remote access policy defining who may use VPN, under what conditions, and add basic usage logging.	
AU-2	Audit & Accountability	Event Logging: Default OS/EHR logging exists but isn't configured intentionally.	Partial	IT Support Specialist	Define which events must be logged (logins, PHI record access, failed access attempts) and confirm systems are configured accordingly.	
AU-6	Audit & Accountability	Audit Record Review, Analysis, and Reporting: No one reviews logs unless an issue is already reported.	Missing	IT Support Specialist	Implement a monthly log review routine, even if manual, to catch anomalies before they become incidents.	
IR-1	Incident Response	Incident Response Policy & Procedures: No documented incident response plan exists.	Missing	Clinic Director	Approve and formally adopt a written incident response policy outlining roles, escalation, and response steps.	
IR-4	Incident Response	Incident Handling: IT support reacts to issues ad hoc; no formal containment/eradication process.	Partial	IT Support Specialist	Build a basic incident handling runbook covering identification, containment, and recovery steps.	
IR-6	Incident Response	Incident Reporting: No defined process for HIPAA breach notification timelines.	Missing	Clinic Director	Document HIPAA breach notification timelines and designate who is responsible for notifying HHS/affected patients if needed.	
IA-2	Identification & Authentication	Identification and Authentication (Org. Users): Each staff member has an individual login — no shared accounts.	Implemented	IT Support Specialist	Maintain current practice; include unique-ID requirement explicitly in the account management policy.	
IA-5	Identification & Authentication	Authenticator Management: Passwords required but no MFA, no enforced complexity/rotation policy.	Partial	IT Support Specialist	Enable MFA on the EHR and email systems, and enforce a minimum password complexity standard.	

Riverside Physical Therapy — NIST 800-53 Control Matrix

Mini Compliance Program | Framework: NIST SP 800-53 (HIPAA-aligned) | Prepared by Kevin Liao

Control ID	Family	Requirement	Current Status	Owner	Needed Actions / Remediation	Notes
SC-7	System & Communications Protection	Boundary Protection: Basic firewall in place at the router level; no segmentation between clinical and admin systems.	Partial	IT Support Specialist	Segment clinical systems (EHR) from general office/guest network traffic.	
SC-8	System & Communications Protection	Transmission Confidentiality and Integrity: Email is not consistently encrypted when PHI may be discussed.	Missing	IT Support Specialist	Adopt an encrypted email solution or secure patient portal for any communication involving PHI.	
SC-28	System & Communications Protection	Protection of Information at Rest: EHR vendor encrypts data at rest; backups are not separately verified as encrypted.	Partial	IT Support Specialist	Confirm and document that backup storage is encrypted, not just the primary EHR database.	
CP-9	Contingency Planning	System Backup: Automated backups run regularly via EHR vendor/cloud storage.	Implemented	IT Support Specialist	Maintain current backup schedule; document backup frequency and retention period formally.	
CP-10	Contingency Planning	System Recovery and Reconstitution: Backups exist but have never been tested with a restoration drill.	Missing	IT Support Specialist	Conduct a test restoration of backup data at least annually to confirm recoverability.	
CM-2	Configuration Management	Baseline Configuration: New workstations are set up inconsistently depending on who configures them.	Missing	IT Support Specialist	Create a standard configuration checklist for new workstation setup (security settings, required software).	
CM-6	Configuration Management	Configuration Settings: Screen lock enforced via MDM; other hardening settings inconsistent.	Partial	IT Support Specialist	Extend MDM policy to enforce additional hardening settings beyond screen lock (e.g., disabled USB ports, auto-updates).	
CM-8	Configuration Management	System Component Inventory: No formal device/software inventory maintained.	Missing	Office Manager	Build and maintain a simple spreadsheet inventory of all devices, software, and assigned users.	

Riverside Physical Therapy — Compliance

Status	Count
Missing	7
Partial	8
Implemented	3
Total Controls Assessed	18

Owner	Controls Owned
IT Support Specialist	15
Office Manager	1
Clinic Director	2